

Clínica UCH

Reporte ejecutivo de gestión de riesgos de seguridad
Dirigido al Directorio | Evaluación inicial | 09 de septiembre de 2026

Resumen ejecutivo

La Clínica UCH cuenta con 120 empleados, atiende aproximadamente 800 pacientes por día y depende de historias clínicas electrónicas, sistemas de admisión, obras sociales y facturación. La evaluación inicial identifica dos riesgos críticos y cinco altos. Las prioridades son proteger la continuidad de atención, las historias clínicas y la capacidad de recuperación ante incidentes.

Se recomienda aprobar tres planes inmediatos: fortalecer las copias de seguridad, desplegar autenticación multifactor y probar el procedimiento de contingencia de la historia clínica electrónica. Los importes y vencimientos son estimaciones académicas que deben validarse con la dirección y el área financiera.

7	2	5	3
riesgos identificados	riesgos críticos	riesgos altos	planes prioritarios

Top 5 riesgos por nivel

Prioridad	Riesgo	Nivel	Consecuencia principal	Tratamiento
1	R-01. Ransomware en sistemas clínicos	Crítico 20	Indisponibilidad de HCE y admisión; posible pérdida de integridad.	Mitigar
2	R-02. Phishing y robo de credenciales	Crítico 20	Acceso no autorizado a historias clínicas y sistemas institucionales.	Mitigar
3	R-03. Caída del sistema de HCE	Alto 15	Interrupción de consultas, admisión y continuidad asistencial.	Mitigar
4	R-04. Acceso indebido a historias clínicas	Alto 15	Exposición de datos sanitarios, sanciones y daño reputacional.	Mitigar
5	R-06. Pérdida o filtración de backups	Alto 15	Compromiso simultáneo de confidencialidad y recuperación.	Mitigar

Criterio: el nivel resulta de probabilidad por impacto en escala 1 a 5. R-05 obtuvo 12 y R-07 obtuvo 10; ambos permanecen en seguimiento alto.

Estado de los planes de acción

PA-01 Recuperación ante ransomware Diseñar el esquema 3-2-1, aislar una copia y ejecutar una restauración documentada. Responsable: Infraestructura. Vencimiento: 09/10/2026. Presupuesto: ARS 1.500.000. Estado: No iniciado.
PA-02 Autenticación multifactor y anti-phishing Habilitar MFA para cuentas privilegiadas y profesionales y ejecutar una campaña de phishing simulado. Responsable: Seguridad de la información. Vencimiento: 23/10/2026. Presupuesto: ARS 900.000. Estado: No iniciado.
PA-03 Continuidad de la HCE Documentar y probar la atención manual y la recuperación del sistema de historias clínicas electrónicas. Responsables: Sistemas y Dirección médica. Vencimiento: 06/11/2026. Presupuesto: ARS 600.000. Estado: No iniciado.

Recomendaciones prioritarias

1. Aprobar PA-01, PA-02 y PA-03, asignar responsables y revisar semanalmente sus avances.
2. Separar las copias de seguridad de la red productiva, cifrarlas, controlar el acceso y demostrar una restauración exitosa.
3. Aplicar MFA primero a administradores y profesionales con acceso a historias clínicas; complementar con capacitación y simulaciones.
4. Definir objetivos de recuperación, un procedimiento manual y una prueba periódica para mantener la atención durante una caída.
5. Recertificar permisos trimestralmente y revisar accesos a historias clínicas mediante registros y alertas.
6. Validar con la dirección los presupuestos, fechas y controles declarados antes de convertir este registro inicial en el registro operativo.